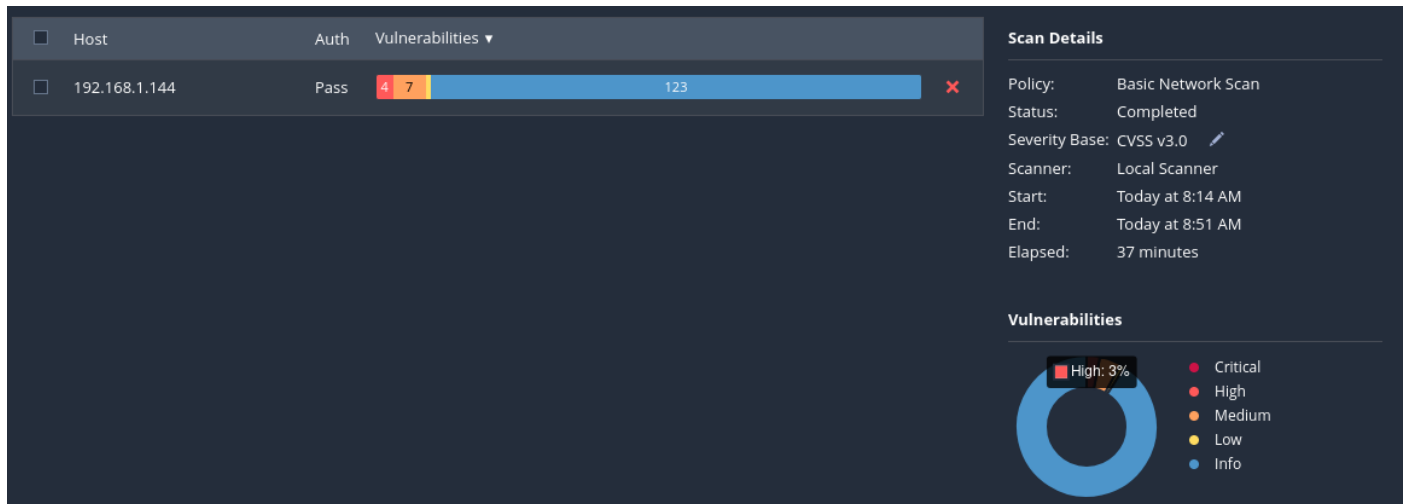


Analyst: AUannat A. Uthman

TITLE: Vulnerability Management Report

TEST ENVIRONMENT



The vulnerability management assessment was conducted on an intentionally vulnerable Kali Linux system that has an old version of Nginx and a poorly configured OpenSSH. The assessment was conducted with Nessus.

VULNERABILITY DISCOVERED

The screenshot shows the 'GiSOC Vulnerability Management Task / Nginx (Multiple...)' interface. It includes a search bar for vulnerabilities and a table listing the discovered vulnerabilities. The table has columns for Severity, CVSS, VPR, EPSS, Name, Family, and Count. Two vulnerabilities are listed, both with a severity of HIGH.

Sev	CVSS	VPR	EPSS	Name	Family	Count
HIGH	7.7			ngin...	Web Servers	1
HIGH	7.5			ngin...	Web Servers	1

1. nginx 0.6.x < 1.20.1 1 - *Byte Memory Overwrite RCE*
2. nginx 1.9.5 < 1.16.1 / 1.17.x < 1.17.3 - *HTTP/2 DOS*

GiSOC Vulnerability Management Task / Plugin #150154

Configure

Audit Trail

Launch

Report

Export

Back to Vulnerability Group

Hosts1

Vulnerabilities73

Remediations5

Notes1

History2

HIGH

nginx 0.6.x < 1.20.1 1-Byte Memory Overwrite RCE

Plugin Details

Severity:High

ID:150154

Version:1.9

Type:combined

Family:Web Servers

Published:June 3, 2021

Modified:September 15, 2022

Description

According to its Server response header, the installed version of nginx is 0.6.18 prior to 1.20.1. It is, therefore, affected by a remote code execution vulnerability. A security issue in nginx resolver was identified, which might allow an unauthenticated remote attacker to cause 1-byte memory overwrite by using a specially crafted DNS response, resulting in worker process crash or, potentially, in arbitrary code execution.

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution

Upgrade to nginx 1.20.1 or later.

See Also

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 7.7

HIGH

nginx 1.9.5 < 1.16.1 / 1.17.x < 1.17.3 Multiple Vulnerabilities

Plugin Details

Severity:High

ID:127907

Version:1.13

Type:combined

Family:Web Servers

Published:August 16, 2019

Modified:May 2, 2024

Description

According to its Server response header, the installed version of nginx is 1.9.5 prior to 1.16.1 or 1.17.x prior to 1.17.3. It is, therefore, affected by multiple denial of service vulnerabilities :

- A denial of service vulnerability exists in the HTTP/2 protocol stack due to improper handling of exceptional conditions. An unauthenticated, remote attacker can exploit this, by manipulating the window size and stream priority of a large data request, to cause a denial of service condition. (CVE-2019-9511)

CVE IDS & CVSS SCORES

1. [CVE-2021-23017](#) | 7.7 High
2. [CVE-2019-9511](#) | 7.5 High

VULNERABILITIES RISK

CVE	CVSS Score	Risk	Solution
CVE-2021-23017	7.7 High	This vulnerability is a security issue in nginx resolver. It might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.	Upgrade to nginx 1.20.1 or later.
CVE-2019-9511	7.5 High	Some HTTP/2 implementations are vulnerable to window size manipulation and stream prioritization manipulation which potentially lead to a denial of service. The attacker requests a large amount of data from a specified resource over multiple streams. They can manipulate window size and stream priority to force the server to queue the data in 1-byte chunks. Depending on how efficiently data is queued, it can consume excess CPU, memory or both thereby leading to Denial of Service (DOS).	Update nginx to 1.16.1 or later. Update libnghttp2 to 1.40.0 or later.

Action	Vulns ▼	Hosts
nginx 0.6.x < 1.20.1 1-Byte Memory Overwrite RCE: Upgrade to nginx 1.20.1 or later.	8	1
Elasticsearch 7.0.x <= 7.17.29 / 8.0.x < 8.18.8 / 8.19.x < 8.19.5 / 9.0.x < 9.0.8 / 9.1.x < 9.1.5 (ESA-2025-18): Upgrade to Elasticsearch version 8.18.8, 8.19.5, 9.0.8, or 9.1.5 or later as appropriate for your release branch.	1	1
OpenSSH < 10.1 / 10.1p1 RCE: Upgrade to OpenSSH version 10.1/10.1p1 or later.	1	1
Ruby REXML 3.3.3 < 3.4.2 DoS vulnerability: Upgrade to REXML version 3.4.2 or later.	1	1
actionmailer Ruby Library 3.x < 6.1.7.9 / 7.0.x < 7.0.8.5 / 7.1.x < 7.1.4.1 / 7.2.x < 7.2.1.1 DoS (CVE-2024-47889): Upgrade to actionmailer version 6.1.7.9, 7.0.8.5, 7.1.4.1, 7.2.1.1 or later.	1	1

CHALLENGES FACED

Asides from SSH config issues I faced initially which I didn't know I could overlook, a challenge I faced was being locked out of my Nessus dashboard because I forgot my login credentials. I, however, did some research and learnt that I could reset it in terminal which I successfully did.